

TechNova Systems — Incident Response & Forensic Analysis Report

DFIR Report — Compromised IIS Server

Yanis Lounadi, Julien Laborie

2026-03-06

Contents

1	Executive Summary	1
2	Investigation & Technical Analysis	2
2.1	Technical Incident Overview	2
2.2	Scope & Methodology	3
2.2.1	Systèmes investigués	3
2.2.2	Artefacts analysés	3
2.2.3	Outils utilisés	3
2.2.4	Approche méthodologique	3
2.3	Detailed Findings	3
2.4	Root Cause Analysis	9
2.5	Indicators of Compromise	11
2.6	Attack Chain Reconstruction	11
3	Impact Analysis	13
4	Remediation & Recommendations	14
4.1	Actions immédiates (24 heures)	14
4.2	Actions à court terme (1 semaine)	14
4.3	Actions à long terme (1 mois)	14
5	Appendices	15
5.1	A. Hashes forensiques des artefacts	15
5.2	B. Commandes d'analyse exécutées	15
5.2.1	Analyse PCAP (tshark)	15
5.2.2	Analyse mémoire (Volatility 3)	15
5.2.3	Analyse malware	15
5.3	C. Références MITRE ATT&CK	16

1 Executive Summary

Le centre opérationnel de sécurité (SOC) de TechNova Systems a détecté un trafic sortant suspect en provenance d'un serveur IIS Windows Server 2019 exposé publiquement.

L'investigation forensique menée sur trois artefacts — une capture réseau, un vidage mémoire complet et un échantillon de malware — a permis de reconstituer la chaîne d'attaque dans son intégralité.

Un attaquant opérant depuis l'adresse 10.0.2.4 a conduit un balayage de ports sur le serveur cible 10.0.2.15, identifié un partage SMB accessible, puis déposé un web-shell ASP.NET (shell.aspx) via le protocole SMB2. Ce web-shell a été utilisé pour établir un reverse shell sur le port 4443, offrant à l'attaquant un accès interactif au serveur. Il a ensuite déployé updatenow.exe, un implant de la famille **Agent Tesla**, dans le répertoire de démarrage automatique afin d'assurer sa persistance. Ce malware exfiltre les données dérobées (frappes clavier, credentials, captures d'écran) via le protocole SMTP vers le serveur cp8nl.hyperhost.ua.

Impact : Le serveur IIS est intégralement compromis. L'ensemble des identifiants ayant transité par cette machine est potentiellement exfiltré. Le mécanisme de persistance assure la survie du malware après redémarrage.

Recommandations critiques : Isoler immédiatement le serveur du réseau, bloquer les indicateurs de compromission identifiés sur l'ensemble de l'infrastructure, révoquer tous les credentials associés au serveur, et fermer l'accès SMB entrant sur les serveurs exposés.

2 Investigation & Technical Analysis

2.1 Technical Incident Overview

Le serveur IIS compromis (adresse IP 10.0.2.15) est un serveur Windows Server 2019 hébergé sur l'infrastructure cloud de TechNova Systems. Ce serveur, exposé publiquement, assure l'hébergement de services web pour l'entreprise.

L'alerte initiale a été déclenchée par le SOC suite à la détection de connexions sortantes inhabituelles depuis ce serveur vers des destinations non répertoriées. L'analyse préliminaire a mis en évidence un trafic SMTP sortant anormal ainsi qu'une connexion persistante vers le port 4443 d'un hôte externe.

Trois artefacts ont été collectés pour mener l'investigation forensique : une capture réseau couvrant la période de l'intrusion, un vidage mémoire complet du serveur (4,5 Go), et un binaire suspect découvert dans le répertoire de démarrage automatique.

2.2 Scope & Methodology

2.2.1 Systèmes investigués

Système	Adresse IP	Rôle
Serveur IIS (victime)	10.0.2.15	Serveur web Windows Server 2019
Machine attaquante	10.0.2.4	Source de l'attaque identifiée

2.2.2 Artefacts analysés

Artefact	Fichier	Taille	Description
Capture réseau	capture.pcapng	3,7 Mo	Trafic réseau de l'intrusion
Vidage mémoire	memdump.mem	4,5 Go	Dump mémoire complet du serveur
Malware	updatenow.exe	588 Ko	Binaire malveillant récupéré sur le disque

2.2.3 Outils utilisés

- **Analyse réseau** : tshark (Wireshark CLI) pour le décodage et le filtrage de la capture PCAP
- **Forensique mémoire** : Volatility 3 avec les plugins windows.info, windows.pstree et windows.netscan
- **Analyse statique du malware** : file, strings, upx -d, sha256sum, md5sum
- **Analyse dynamique** : Sandbox ANY.RUN pour l'analyse comportementale et l'identification par règles YARA

2.2.4 Approche méthodologique

L'investigation a suivi le principe de l'ordre de volatilité, en analysant les artefacts du plus volatile au plus stable : le trafic réseau (capture PCAP) a été traité en premier pour reconstituer la chronologie de l'attaque, le vidage mémoire a ensuite permis d'identifier les processus et connexions actifs au moment de l'acquisition, et enfin l'analyse du malware a caractérisé la charge utile déployée par l'attaquant.

2.3 Detailed Findings

2.3.0.1 Analyse du trafic réseau (PCAP)

L'analyse de la capture réseau capture.pcapng (3,7 Mo) constitue le point de départ de l'investigation. Elle permet de reconstituer chronologiquement les différentes phases de l'attaque, depuis la reconnaissance initiale jusqu'à l'établissement d'un canal de commande et contrôle. L'ensemble des extractions a été réalisé à l'aide de tshark, l'interface en ligne de commande de Wireshark, afin de garantir la reproductibilité des résultats.

2.3.0.1.1 Phase 1 — Reconnaissance par balayage de ports

L'examen des statistiques de conversation TCP révèle un volume anormal d'échanges entre deux hôtes du réseau interne. La commande suivante a été utilisée pour obtenir une vue synthétique :

```
tshark -r capture.pcapng -z conv,tcp -q
```

Statistiques de conversation TCP — `tshark -r capture.pcapng -z conv,tcp -q`

Figure 1: Statistiques de conversation TCP — `tshark -r capture.pcapng -z conv,tcp -q`

Le résultat met en évidence une conversation totalisant **6 007 trames** entre la machine source 10.0.2.4 (identifiée comme l'attaquant) et la machine cible 10.0.2.15 (le serveur IIS compromis). Un filtrage complémentaire sur les paquets SYN sans acquittement — caractéristiques d'un balayage de type *SYN scan* — confirme l'hypothèse :

```
tshark -r capture.pcapng -Y "tcp.flags.syn == 1 && tcp.flags.ack == 0 && ip.src == 10.0.2.4 && ip.dst == 10.0.2.15"
```

Cette extraction dénombre **1 002 ports distincts** ciblés par le balayage, ce qui correspond au comportement classique d'un outil de reconnaissance tel que Nmap. Cette activité est rattachée à la technique **MITRE ATT&CK T1046 — Network Service Scanning**.

2.3.0.1.2 Phase 2 — Énumération des partages SMB

Une fois les services ouverts identifiés, l'attaquant a procédé à l'énumération des ressources partagées via le protocole SMB. L'analyse des requêtes DCERPC ciblant l'interface `srvsvc` avec l'opération `NetShareEnumAll` (opnum 15) a été réalisée avec la commande :

```
tshark -r capture.pcapng -Y "dcerpc.opnum == 15" -T fields -e ip.src -e ip.dst
```

Cette requête, émise depuis 10.0.2.4 à destination de 10.0.2.15, permet à l'attaquant de lister l'intégralité des partages disponibles sur le serveur cible. Les connexions aux arborescences SMB2 (*Tree Connect*) confirment ensuite l'accès effectif aux ressources découvertes :

```
tshark -r capture.pcapng -Y "smb2.cmd == 3 && smb2.flags.response == 0" -T fields -e frame.number -e smb2.tree
```

Filtre SMB2 Tree Connect — `smb2.cmd == 3`

Figure 2: Filtre SMB2 Tree Connect — `smb2.cmd == 3`

Deux connexions sont particulièrement significatives : la première vers `\\10.0.2.15\IPC$` (trame 2672), utilisée pour l'énumération RPC, et la seconde vers `\\10.0.2.15\Documents` (trame 2678), exploitée par la suite pour le dépôt de la charge malveillante.

2.3.0.1.3 Phase 3 — Dépôt du web-shell

L'étape la plus critique de la compromission initiale est le téléversement d'un web-shell sur le serveur IIS. L'analyse des opérations d'écriture SMB2 a été conduite à l'aide du filtre suivant :

```
tshark -r capture.pcapng -Y "smb2.cmd == 9" -T fields -e frame.number -e  
smb2.filename -e smb2.write_length
```

Requête SMB2 Write montrant l'upload de shell.aspx

Figure 3: Requête SMB2 Write montrant l'upload de shell.aspx

Les résultats révèlent le dépôt du fichier `shell.aspx` aux alentours de la trame 3505, pour un volume total de **1 015 024 octets** (environ 1 Mo). La taille du fichier et son extension `.aspx` indiquent un web-shell destiné à être interprété par le moteur IIS, offrant ainsi à l'attaquant une capacité d'exécution de commandes arbitraires sur le serveur via une interface HTTP.

2.3.0.1.4 Phase 4 — Établissement du reverse shell

Immédiatement après le dépôt et l'activation du web-shell, le trafic réseau révèle l'établissement d'une connexion sortante depuis le serveur compromis vers l'infrastructure de l'attaquant. La trame 3585 marque le début de cette session : le serveur victime initie une connexion TCP depuis le port éphémère 49688 vers le port 4443 de la machine 10.0.2.4.

Connexion reverse shell — SYN sortant vers 10.0.2.4:4443

Figure 4: Connexion reverse shell — SYN sortant vers 10.0.2.4:4443

Le choix du port **4443** par l'attaquant est délibéré : ce port est fréquemment associé à des services HTTPS alternatifs, ce qui permet de contourner les mécanismes de détection basés sur des listes de ports suspects. Ce canal constitue le *reverse shell* par lequel l'attaquant a obtenu un accès interactif complet au serveur, ouvrant la voie aux actions ultérieures de post-exploitation, notamment le dépôt du binaire de persistance `updatenow.exe`.

2.3.0.1.5 Synthèse de la chaîne d'attaque réseau

L'analyse du trafic réseau permet de reconstituer une séquence d'attaque en quatre temps clairement délimités : reconnaissance par balayage SYN de plus d'un millier de ports, énumération des partages SMB via DCERPC, dépôt d'un web-shell ASP.NET par écriture SMB2, puis établissement d'un canal de commande et contrôle inverse sur le port 4443. L'ensemble de ces actions a été conduit depuis l'adresse 10.0.2.4 à l'encontre du serveur 10.0.2.15, dans un intervalle temporel restreint témoignant d'une attaque méthodique et automatisée.

2.3.0.2 Analyse forensique de la mémoire

L'analyse du vidage mémoire constitue une étape déterminante de l'investigation, car elle permet de reconstituer l'état exact du système compromis au moment de l'acquisition. Le fichier `memdump.mem`, d'une taille de 4,5 Go, a été traité à l'aide du framework **Volatility 3**, outil de référence en forensique mémoire.

2.3.0.2.1 Identification du système

La première opération consiste à identifier le système d'exploitation et à valider l'intégrité de l'image mémoire. La commande suivante a été exécutée :

```
vol -f memdump.mem windows.info
```

Les résultats révèlent un système **Windows Server 2019** (version 10.0.17763) fonctionnant en architecture `x86_64`, avec une base noyau située à l'adresse `0xf80079213000`. La racine système est localisée dans `C:\Windows` et le type de produit `NtProductServer` confirme qu'il s'agit bien d'un serveur de production. L'horodatage d'acquisition du vidage est fixé au **10 septembre 2024 à 06:14:13 UTC**, ce qui établit la borne temporelle supérieure de notre analyse.

Informations système — `vol -f memdump.mem windows.info`

Figure 5: Informations système — `vol -f memdump.mem windows.info`

2.3.0.2.2 Analyse de l'arborescence des processus

L'examen de l'arborescence des processus constitue le cœur de l'analyse mémoire. En reconstruisant les relations parent-enfant, il est possible de retracer la chaîne d'exécution complète de l'attaque. La commande utilisée est la suivante :

```
vol -f memdump.mem windows.pstree
```

L'arborescence met en évidence une chaîne de processus particulièrement révélatrice. Le service IIS, géré par `services.exe` (PID 628), engendre le processus `svchost.exe` (PID 2452) avec le paramètre `-k iissvcs`, lequel supervise le processus de travail `w3wp.exe` (PID 4332). C'est ce dernier — le *worker process* d'IIS — qui a donné naissance au processus malveillant `updatenow.exe` (PID 900), créé le 10 septembre 2024 à 06:08:23 UTC. Le fait qu'un processus IIS engendre directement un exécutable arbitraire constitue un indicateur de compromission sans équivoque : cela confirme que l'attaquant a exploité le web-shell préalablement déposé sur le serveur pour exécuter du code sur la machine.

L'exécutable `updatenow.exe` est localisé dans le répertoire `C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\`, ce qui correspond à la technique de persistance **MITRE ATT&CK T1547.001** (*Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder*). Ce mécanisme garantit la réexécution automatique du malware à chaque ouverture de session. Il est également notable que le processus fonctionne en mode **Wow64** (valeur `True`), indiquant qu'il s'agit d'un binaire 32 bits exécuté

sur un système d'exploitation 64 bits — caractéristique fréquente des charges utiles générées par des frameworks d'attaque automatisés.

Un second processus suspect a été identifié : RegSvcs.exe (PID 4200), dont la ligne de commande pointe vers C:\Users\admin\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\update.exe. Le processus RegSvcs.exe est un utilitaire légitime du framework .NET, mais son invocation avec un chemin d'exécution pointant vers un dossier de démarrage utilisateur constitue un indicateur fort de **process hollowing** — technique par laquelle l'attaquant injecte du code malveillant dans l'espace mémoire d'un processus légitime afin d'échapper aux mécanismes de détection.

Arbre de processus montrant la chaîne w3wp.exe → updatenow.exe

Figure 6: Arbre de processus montrant la chaîne w3wp.exe → updatenow.exe

2.3.0.2.3 Analyse des connexions réseau

L'examen des connexions réseau actives au moment de l'acquisition mémoire permet de caractériser les communications établies par les processus compromis. La commande suivante a été exécutée :

```
vol -f memdump.mem windows.netscan
```

L'analyse révèle une connexion réseau associée au processus w3wp.exe (PID 4332), établie depuis l'adresse de la machine victime 10.0.2.15 sur le port source 49688 vers l'adresse de l'attaquant 10.0.2.4 sur le **port 4443**. Cette connexion, dont l'état est CLOSED au moment du vidage, a été créée le 10 septembre 2024 à 05:49:51 UTC — soit environ dix-huit minutes avant l'exécution de updatenow.exe. Le port 4443 est un port non standard fréquemment utilisé pour les *reverse shells* chiffrés, ce qui corrobore le scénario d'un accès interactif de l'attaquant au système compromis, préalable au déploiement de la charge utile persistante.

Connexions réseau — vol -f memdump.mem windows.netscan

Figure 7: Connexions réseau — vol -f memdump.mem windows.netscan

2.3.0.2.4 Synthèse de l'analyse mémoire

La corrélation des éléments extraits du vidage mémoire permet de reconstituer la chronologie suivante : l'attaquant a d'abord établi un *reverse shell* via le processus IIS w3wp.exe à 05:49:51 UTC, lui conférant un accès interactif au serveur. Il a ensuite exploité cet accès pour déposer et exécuter le malware updatenow.exe à 06:08:23 UTC dans le dossier de démarrage automatique, assurant ainsi sa persistance sur le système. L'utilisation conjointe de techniques d'évasion — binaire 32 bits sur un système 64 bits et probable *process hollowing* via RegSvcs.exe — témoigne d'un adversaire méthodique cherchant à maintenir un accès furtif et durable à l'infrastructure compromise.

2.3.0.3 Analyse du malware

L'artefact `updatenow.exe`, récupéré dans le répertoire de démarrage automatique du serveur compromis, a fait l'objet d'une analyse statique puis dynamique afin de caractériser sa nature, ses capacités et son infrastructure de commande et contrôle.

2.3.0.3.1 Identification et caractérisation initiale

L'examen préliminaire du fichier a été réalisé à l'aide de la commande `file`, qui a permis d'identifier un exécutable Windows 32 bits à interface graphique d'une taille de 588 Ko (602 112 octets) :

```
file updatenow.exe
# PE32 executable (GUI) Intel 80386, for MS Windows, UPX compressed
```

Les empreintes cryptographiques du binaire ont été calculées afin de permettre son identification formelle et sa corrélation avec les bases de renseignement sur les menaces :

```
sha256sum updatenow.exe
# c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f

md5sum updatenow.exe
# d797600296ddb4497725579d814b7e
```

L'analyse des en-têtes de sections a immédiatement révélé la présence de sections caractéristiques d'un packer UPX (`UPX0`, `UPX1`, `UPX!`), indiquant que le binaire avait été compressé afin d'entraver l'analyse statique et d'échapper aux signatures antivirus.

Identification du packer UPX — file `updatenow.exe`

Figure 8: Identification du packer UPX — file `updatenow.exe`

2.3.0.3.2 Décompression et extraction de chaînes

Le binaire a été décompressé à l'aide de l'outil UPX afin de permettre une analyse plus approfondie de son contenu :

```
upx -d updatenow.exe -o updatenow_unpacked.exe
```

Le fichier décompressé atteint une taille de 1 084 928 octets, soit un ratio de compression d'environ 55 %, ce qui est cohérent avec un packing UPX standard. L'extraction des chaînes de caractères lisibles du binaire décompressé a ensuite été effectuée :

```
strings updatenow_unpacked.exe
```

Cette opération a permis d'identifier plusieurs éléments significatifs sur le plan forensique. Toutefois, la configuration du canal de commande et contrôle s'est révélée chiffrée dans le binaire et résolue uniquement à l'exécution, rendant nécessaire le recours à une analyse dynamique pour extraire les paramètres de communication du malware.

Chaînes extraites du binaire décompressé

Figure 9: Chaînes extraites du binaire décompressé

2.3.0.3.3 Analyse dynamique en sandbox

Le binaire a été soumis à la plateforme d'analyse comportementale ANY.RUN afin d'observer son comportement en environnement contrôlé. Les règles YARA et les indicateurs comportementaux ont permis d'identifier formellement l'échantillon comme appartenant à la famille **Agent Tesla** (référence MITRE ATT&CK : S0331), un infostealer et keylogger développé en .NET largement documenté dans la littérature de renseignement sur les menaces.

Résultat sandbox ANY.RUN — détection Agent Tesla

Figure 10: Résultat sandbox ANY.RUN — détection Agent Tesla

L'analyse comportementale a confirmé les capacités suivantes du malware :

- **Enregistrement de frappes clavier** (keylogging) permettant la capture d'identifiants saisis par les utilisateurs
- **Capture du presse-papiers** et réalisation de **captures d'écran** à intervalles réguliers
- **Vol de credentials** stockés dans les navigateurs web, clients FTP et clients de messagerie
- **Collecte d'informations système** (nom de machine, utilisateur, configuration réseau) à des fins de profilage de la victime
- **Exfiltration des données** via les protocoles SMTP, FTP ou HTTP selon la configuration déployée

2.3.0.3.4 Infrastructure de commande et contrôle

L'analyse réseau réalisée dans la sandbox a révélé que l'échantillon établit une connexion SMTP sortante sur le port 587 vers le serveur cp8nl.hyperhost.ua (adresse IP : 185.174.175.187). Le malware utilise le compte de messagerie blessed4ever@genesio.top comme vecteur d'exfiltration, transmettant les données dérobées sous forme de courriels vers une boîte contrôlée par l'attaquant. Ce mode d'exfiltration par SMTP est caractéristique des déploiements d'Agent Tesla et présente l'avantage, du point de vue de l'attaquant, de se fondre dans le trafic de messagerie légitime.

Connexions réseau ANY.RUN — SMTP vers cp8nl.hyperhost.ua

Figure 11: Connexions réseau ANY.RUN — SMTP vers cp8nl.hyperhost.ua

L'ensemble de ces éléments confirme que le fichier updatenow.exe constitue un implant de type Agent Tesla, déposé sur le serveur compromis comme mécanisme de persistance et d'exfiltration de données. Son installation dans le répertoire de démarrage automatique garantit sa réexécution à chaque redémarrage du système, conformément à la technique de persistance MITRE ATT&CK T1547.001.

2.4 Root Cause Analysis

L'analyse des causes profondes de cet incident met en lumière plusieurs défaillances de sécurité ayant collectivement permis la compromission du serveur.

Point d'entrée principal : Le service SMB (port 445) était accessible depuis le réseau de l'attaquant sans mécanisme d'authentification renforcé. Le partage Documents, découvert par énumération, était directement mappé au répertoire racine du serveur IIS (*webroot*), créant un vecteur d'attaque permettant le dépôt de fichiers interprétables par le serveur web.

Absence de segmentation réseau : L'accès au port SMB depuis un segment réseau non autorisé indique une absence de cloisonnement réseau (DMZ) entre les serveurs web exposés et le reste de l'infrastructure. Une segmentation appropriée aurait empêché l'attaquant d'atteindre le service SMB.

Absence de monitoring du trafic sortant : La connexion reverse shell sur le port 4443 et le trafic SMTP d'exfiltration n'ont pas été détectés en temps réel. Seule une analyse a posteriori a permis d'identifier ces flux, indiquant l'absence de règles de détection sur le trafic sortant non standard.

Absence de protection endpoint : Aucune solution EDR ou antivirus n'a bloqué l'exécution du binaire *updatenow.exe* ni détecté le comportement anormal du processus *w3wp.exe* engendrant un exécutable non légitime. La technique de *process hollowing* via *RegSvcs.exe* n'a pas non plus été interceptée.

2.5 Indicators of Compromise

Type	Valeur	Description
IP	10.0.2.4	Attaquant — source du scan, énumération SMB et reverse shell
IP	185.174.175.187	Serveur SMTP utilisé pour l'exfiltration Agent Tesla
Domain	cp8nl.hyperhost.ua	FQDN du serveur C2 (résolution SMTP)
Email	blessed4ever@genesio.top	Compte SMTP utilisé pour l'exfiltration
SHA256	c25a66751a25bde1bb399d226c12cdc666e0fa534149fc9fa789614066	updatenow.exe (Agent Tesla)
MD5	d797600296ddbed4497725579d814b7e	updatenow.exe (Agent Tesla)
Filename	shell.aspx	Web-shell ASP.NET uploadé via SMB
Filename	updatenow.exe	Implant Agent Tesla (persistance)
Path	C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\updatenow.exe	Emplacement de persistance (Startup Folder)
Path	C:\Users\admin\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\update.exe	Second implant suspect (process hollowing)
Port	4443/tcp	Port du reverse shell listener
Port	587/tcp	Port SMTP utilisé pour l'exfiltration
Process	w3wp.exe (PID 4332)	Processus IIS compromis (reverse shell + spawn malware)
Process	updatenow.exe (PID 900)	Processus malveillant Agent Tesla
Process	RegSvc.exe (PID 4200)	Processus légitime détourné (process hollowing)

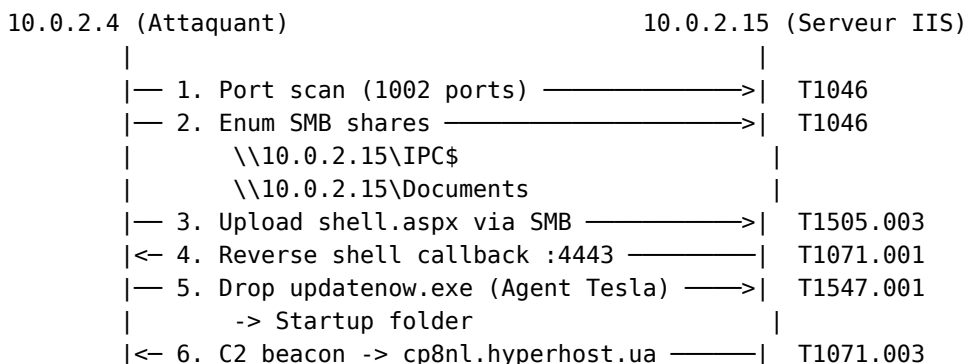
2.6 Attack Chain Reconstruction

La reconstruction chronologique de l'attaque, corrélant les trois sources d'artefacts, est présentée dans le tableau ci-dessous. Chaque phase est mappée au framework MITRE ATT&CK.

Timestamp (UTC)	Phase	Action	Source	MITRE ATT&CK
~05:45	Recon- nais- sance	Balayage SYN de 1 002 ports sur 10.0.2.15	PCAP : conversa- tion statis- tics	T1046 — Network Service Scanning
~05:46	Discov- ery	Énuméra- tion SMB : Tree Con- nect vers IPC\$ et Docu- ments, NetSha- reEnu- mAll via DCERPC	PCAP : smb2.cmd 3, dcerpc.opnum == 15	T1046 — Network Service Discovery
~05:47	Initial Access	Upload du web-shell shell.asp (1 015 024 octets) via SMB2 Write	PCAP : smb2.cmd == 9	T1505.003 — Server Software Component: Web Shell
05:49:51	Com- mand & Control	Établisse- ment du reverse shell : 10.0.2.15:49688 → 10.0.2.4:4443	Memory : windows.net scan	T1071.001 — Appli- cation Layer Protocol: Web Protocols
06:08:23	Persé- cution	Dépôt de updates dans le Startup Folder	Memory : windows.p tree	T1547.001 — Boot or Logon Autostart Exe- cution: Startup Folder
06:08+	Execu- tion	Exécution d'Agent Tesla, process hollowing via RegSvcs.exe	Memory : windows.p tree	T1055.012 — Process Injection: Process Hollowing
06:08+	Exfiltra- tion	Beacon SMTP vers cp8nl.hyperhost. 12	Malware : sandbox ANY.RUN	T1071.003 — Appli- cation Layer Protocol: Mail Protocols

Diagramme de la kill chain — à créer dans draw.io ou Excalidraw, reprenant le schéma ci-dessous

Figure 12: Diagramme de la kill chain — à créer dans draw.io ou Excalidraw, reprenant le schéma ci-dessous



3 Impact Analysis

La compromission du serveur IIS de TechNova Systems entraîne les impacts suivants :

Systèmes compromis : Le serveur Windows Server 2019 (10.0.2.15) est intégralement compromis. L'attaquant a disposé d'un accès interactif via reverse shell et a déployé un implant persistant. L'intégrité de l'ensemble des données et configurations hébergées sur ce serveur ne peut plus être garantie.

Exfiltration de données : Agent Tesla est un keylogger et infostealer actif. L'ensemble des identifiants saisis sur le serveur depuis l'installation du malware — mots de passe administrateur, credentials de bases de données, tokens d'API — sont potentiellement compromis et exfiltrés via SMTP vers l'infrastructure de l'attaquant. Les captures d'écran périodiques réalisées par le malware ont également pu exposer des données sensibles affichées à l'écran.

Persistance établie : Le mécanisme de persistance via le Startup Folder garantit la réexécution automatique du malware après chaque redémarrage. Tant que le binaire n'est pas supprimé et les IoCs bloqués, le serveur reste sous le contrôle de l'attaquant.

Risque de mouvement latéral : Depuis le serveur compromis, l'attaquant dispose potentiellement d'un accès au réseau interne de TechNova. Les credentials volés pourraient permettre un mouvement latéral vers d'autres systèmes (serveurs de bases de données, contrôleurs de domaine, postes de travail).

Impact opérationnel : L'isolation du serveur, nécessaire pour stopper l'exfiltration, entraînera une interruption des services web hébergés. La durée de remédiation dépendra de l'étendue de la compromission dans le reste de l'infrastructure.

4 Remediation & Recommendations

4.1 Actions immédiates (24 heures)

1. **Isoler le serveur** : Déconnecter immédiatement le serveur 10.0.2.15 du réseau pour stopper l'exfiltration active via SMTP et le canal de commande et contrôle.
2. **Bloquer les IoCs** : Déployer les règles de blocage sur l'ensemble de l'infrastructure (pare-feu, proxy, DNS) pour les adresses IP 10.0.2.4 et 185.174.175.187, le domaine cp8n1.hyperhost.ua, et les ports 4443 et 587 en sortie non autorisée.
3. **Révoquer les credentials** : Forcer la rotation de tous les identifiants ayant transité par le serveur compromis — comptes administrateur, credentials de services, tokens d'API, clés SSH.
4. **Supprimer les artefacts malveillants** : Retirer updatenow.exe du Startup Folder, update.exe du profil admin, et shell.aspx du webroot IIS.

4.2 Actions à court terme (1 semaine)

5. **Fermer l'accès SMB** : Bloquer le port 445 en entrée sur tous les serveurs exposés publiquement. Restreindre l'accès SMB aux seuls segments réseau légitimes via des règles de pare-feu granulaires.
6. **Déployer un EDR** : Installer une solution de détection et réponse sur les endpoints (EDR) sur l'ensemble des serveurs de production, avec des règles spécifiques pour la détection de process hollowing et d'exécution anormale depuis les processus IIS.
7. **Segmenter le réseau** : Placer les serveurs web dans une DMZ dédiée avec un contrôle strict des flux entrants et sortants. Interdire les connexions directes entre la DMZ et le réseau interne.
8. **Auditer les partages SMB** : Recenser et vérifier les permissions de l'ensemble des partages réseau. S'assurer qu'aucun partage n'est mappé à un webroot ou à un répertoire sensible.

4.3 Actions à long terme (1 mois)

9. **Monitoring SMTP sortant** : Mettre en place des alertes sur les connexions SMTP sortantes non autorisées, en particulier vers des serveurs de messagerie externes non répertoriés.
10. **Hardening IIS** : Appliquer les recommandations de durcissement Microsoft pour IIS — désactiver les protocoles inutiles, restreindre les extensions de fichiers exécutables (.aspx, .asp, .php), activer le logging détaillé.
11. **Formation SOC** : Former les analystes SOC à la détection des techniques observées dans cet incident : reverse shells sur ports non standard, process hollowing, exfiltration SMTP.
12. **Revue périodique** : Instaurer une revue trimestrielle des règles de pare-feu, des permissions de partage réseau et des configurations de sécurité des serveurs exposés.

5 Appendices

5.1 A. Hashes forensiques des artefacts

Artefact	SHA256
capture.pcapng	<i>À calculer : sha256sum capture.pcapng</i>
memdump.mem	<i>À calculer : sha256sum memdump.mem</i>
updatenow.exe	c25a6673a24d169de1bb399d226c12cdc666e0fa534149fc9fa7896ee61d406f

5.2 B. Commandes d'analyse exécutées

5.2.1 Analyse PCAP (tshark)

Statistiques de conversation TCP

```
tshark -r capture.pcapng -z conv,tcp -q
```

Détection de l'énumération DCERPC NetShareEnumAll

```
tshark -r capture.pcapng -Y "dcerpc.opnum == 15" -T fields -e ip.src -e ip.dst
```

Tree Connect SMB2

```
tshark -r capture.pcapng -Y "smb2.cmd == 3 && smb2.flags.response == 0" -T fields -e frame.number -e smb2.tree
```

Opérations d'écriture SMB2 (upload web-shell)

```
tshark -r capture.pcapng -Y "smb2.cmd == 9" -T fields -e frame.number -e smb2.filename -e smb2.write_length
```

Connexions sortantes SYN (reverse shell)

```
tshark -r capture.pcapng -Y "tcp.flags.syn == 1 && tcp.flags.ack == 0 && ip.src == 10.0.2.15 && ip.dst == 10.0.2.4"
```

5.2.2 Analyse mémoire (Volatility 3)

Informations système

```
vol -f memdump.mem windows.info
```

Arbre de processus

```
vol -f memdump.mem windows.pstree
```

Connexions réseau

```
vol -f memdump.mem windows.netscan
```

5.2.3 Analyse malware

Identification du type de fichier

```
file updatenow.exe
```

```
# Calcul des empreintes
sha256sum updatenow.exe
md5sum updatenow.exe

# Décompression UPX
upx -d updatenow.exe -o updatenow_unpacked.exe

# Extraction de chaînes
strings updatenow_unpacked.exe
```

5.3 C. Références MITRE ATT&CK

ID	Technique	Phase	Utilisation dans l'incident
T1046	Network Service Scanning	Reconnaissance / Discovery	Balayage de 1 002 ports + énumération SMB
T1505.003	Server Software Component: Web Shell	Initial Access	Upload de shell.aspx via SMB
T1071.001	Application Layer Protocol: Web Protocols	Command & Control	Reverse shell sur port 4443
T1547.001	Boot or Logon Autostart Execution: Startup Folder	Persistence	updatenow.exe dans le Startup Folder
T1055.012	Process Injection: Process Hollowing	Defense Evasion	RegSvc.exe détourné par update.exe
T1071.003	Application Layer Protocol: Mail Protocols	Exfiltration	Exfiltration SMTP vers cp8nl.hyperhost.ua
S0331	Agent Tesla	—	Famille de malware identifiée